DERECHO INFORMÁTICO · URUGUAY Y EL MUNDO

Ciberdelito, ciberdefensa y privacidad internacional

Marco jurídico uruguayo, cooperación internacional y protección de datos personales.

Ponentes: Sandra Barrera y Matias Bardo

Profesor: Nelson Connio

La pregunta central: ¿Cómo responder cuando el atacante, la víctima, los servidores y los datos están en países distintos?

Delitos, soberanía y datos que cruzan fronteras.



Índice

Contexto

Lámina 3

Ciberdelitos en Uruguay

Láminas 4–9

Cooperación internacional

Láminas 10–12

Ciberdefensa y soberanía

Láminas 13–15

GDPR

Láminas 16–22

Ley 18.331 y comparación internacional

Láminas 23–26

Cierre y gracias

Láminas 27–28

¿Qué es la ciberdelincuencia?

Comprende conductas delictivas que atacan sistemas y datos o que utilizan medios digitales para afectar a las personas y sus bienes.

La tecnología es el objetivo

Ejemplos: acceso ilícito a datos, interceptación de transmisiones y daño informático.

La tecnología es el medio

Ejemplos: fraude, acoso telemático y contacto con menores con finalidad sexual.

Técnica y delito

Phishing y ransomware describen modalidades de ataque. La calificación penal depende de las conductas, la intención y los demás requisitos del tipo aplicable.

Primero se identifican los hechos; después se determina la norma penal.

Fuentes: U1 · U2. Enlaces completos en el anexo.

Ley 20.327: una respuesta penal y preventiva

Promulgada el 23 de agosto de 2024 y publicada el 25 de septiembre de 2024, establece normas de prevención y represión de la ciberdelincuencia.

Arts. 1 a 8: dimensión penal

Incorpora delitos y agravantes al Código Penal y modifica la normativa sobre lavado de activos.

Art. 9: educación

Prevé una campaña nacional sobre finanzas personales y ciberseguridad.

Arts. 10 y 11: prevención financiera

Autoriza determinados registros interinstitucionales y la inmovilización de fondos bajo condiciones legales.

Los artículos de la Ley 20.327 no deben confundirse con los artículos del Código Penal que incorpora.

Fuentes: U1. Enlaces completos en el anexo.

Personas y patrimonio: conducta, ejemplo y pena

Los artículos son del Código Penal. Las penas corresponden a las figuras básicas; las agravantes y el caso concreto requieren análisis separado.

Acoso telemático - art. 288 BIS

Vigilar, perseguir o procurar contacto de forma insistente por medios telemáticos, alterando gravemente la vida de la víctima. Ejemplo hipotético: persecución digital reiterada que obliga a cambiar rutinas.

Pena: tres meses de prisión a tres años de penitenciaría.

Fraude informático - art. 347 BIS

Contempla engaños y manipulaciones digitales para obtener un provecho injusto con perjuicio ajeno, según sus modalidades. Ejemplo: obtener credenciales mediante engaño para una transferencia no consentida.

Remite a la pena del art. 347: seis meses de prisión a cuatro años de penitenciaría.

Suplantación de identidad - art. 347 TER

Apropiarse de la identidad digital ajena con intención de dañar. Ejemplo: usar credenciales de otra persona para perjudicarla.

Pena: un año de prisión a seis años de penitenciaría. La parodia exclusiva está exceptuada.

Las agravantes se regulan, respectivamente, en los arts. 288 TER, 348 BIS y 348 TER.

Fuentes: P1 · P2 · P3 · P4. Enlaces completos en el anexo.

Datos y sistemas: cuatro formas de afectación

No todo incidente es el mismo delito: importa qué se hizo, con qué autorización y con qué finalidad.

Acceso ilícito - art. 297 BIS

Sin autorización y sin justa causa, acceder, interferir, difundir, vender o ceder información digital ajena. Ejemplo: entrar a una base ajena sin permiso. Pena: seis a veinticuatro meses de prisión.

Interceptación - art. 297 TER

Interceptar, interrumpir o interferir técnicamente transmisiones no públicas, sin autorización ni justa causa. Ejemplo: capturar comunicaciones privadas en tránsito. Pena: seis a veinticuatro meses de prisión.

Vulneración de datos - art. 297 QUATER

Acceder, apropiarse, utilizar o modificar datos confidenciales sin autorización: seis a veinticuatro meses de prisión. Difundir, revelar o ceder los datos, hechos o imágenes comprendidos: un año de prisión a cuatro años de penitenciaría.

Daño y abuso de dispositivos - arts. 358 QUATER y QUINQUIES

Destruir, alterar o inutilizar datos o sistemas sin autorización para causar daño; o facilitar ilegítimamente herramientas inequívocamente destinadas a delitos. Cada figura prevé seis a veinticuatro meses de prisión.

Las herramientas de seguridad de uso legítimo no se equiparan automáticamente al abuso del art. 358 QUINQUIES.

Fuentes: P5 · P6 · P7 · P8 · P9. Enlaces completos en el anexo.

Grooming: qué exige el art. 277 BIS

El art. 94 de la Ley 19.580 incorporó esta figura al Código Penal. El art. 2 de la Ley 20.327 agregó sus agravantes mediante el art. 277 TER.

Conducta y finalidad

Contactar o influir sobre una persona menor de edad mediante tecnologías, con el propósito de cometer delitos contra su integridad sexual, actos con connotaciones sexuales, obtener material pornográfico u obligarla a actuar contra su voluntad, según el texto legal.

Encuentro físico y pena

El tipo no exige un encuentro presencial. La figura básica prevé seis meses de prisión a cuatro años de penitenciaría.

Agravantes del art. 277 TER

Coacción, intimidación o engaño; afinidad o parentesco; contacto con menores de trece años o en las condiciones de discapacidad previstas por la norma.

Ejemplo hipotético

Una persona adulta manipula a un adolescente mediante mensajes para obtener contenido sexual. Deben acreditarse el contacto, la finalidad y las circunstancias concretas.

Una comunicación ordinaria entre un adulto y un menor no configura por sí sola esta figura.

Fuentes: U2 · U1. Enlaces completos en el anexo.

Imágenes íntimas: creación y difusión son decisiones distintas

El art. 92 de la Ley 19.580 sanciona difundir, revelar, exhibir o ceder a terceros imágenes o grabaciones íntimas o sexuales sin autorización.

Qué protege

La decisión de una persona sobre la divulgación de su contenido íntimo. Haber participado en las imágenes no habilita a difundirlas.

Pena y protección de menores

La pena es de seis meses de prisión a dos años de penitenciaría. La autorización de una persona menor de dieciocho años no se considera válida a estos efectos.

Sitios y plataformas

El artículo también contempla a administradores de sitios, portales, buscadores o similares que, notificados de la falta de autorización, no retiren inmediatamente el contenido.

Ejemplo hipotético

Una expareja comparte en un grupo una grabación que se realizó de común acuerdo. La aceptación de la grabación no demuestra autorización para compartirla.

Consentir la creación de una imagen no equivale a consentir cualquier difusión posterior.

Fuentes: U3. Enlaces completos en el anexo.

¿Quién interviene ante un ciberdelito?

La respuesta reúne funciones policiales, fiscales, judiciales y técnicas.

Dirección General de Cibercrimen

Realiza la investigación policial especializada y el análisis de evidencia digital.

Fiscalía y órganos judiciales

Fiscalía dirige la investigación penal. Los órganos judiciales adoptan las decisiones y autorizaciones que les corresponden.

CERTuy / Agesic

Actúan en la respuesta y coordinación técnica de incidentes dentro de su ámbito; esa tarea no sustituye la investigación penal.

Denuncia temprana

Conservar mensajes, enlaces, correos y registros. Se puede denunciar con información preliminar y ampliarla después.

La denuncia no necesita esperar a que la víctima reúna toda la prueba.

Fuentes: U11 · U12 · U8. Enlaces completos en el anexo.

La evidencia digital cruza fronteras

Una investigación puede depender de información almacenada o controlada desde otro país.

Qué puede servir como evidencia

Registros de acceso, direcciones IP, correos, mensajes, metadatos y datos de transacciones.

Por qué importa actuar a tiempo

Los registros pueden borrarse, modificarse o dejar de estar disponibles.

Qué límites existen

La preservación evita la pérdida de datos, pero no concede automáticamente su entrega o acceso.

Cómo se interpreta

Una dirección IP es una pista que debe contextualizarse y contrastarse con otros elementos.

Preservar, obtener y valorar la prueba son actuaciones distintas.

Fuentes: U5 · U12. Enlaces completos en el anexo.

Ley 20.004 y Convenio Iberoamericano

La Ley 20.004, promulgada el 25 de noviembre de 2021, aprueba mediante un artículo único el Convenio suscrito en Madrid el 28 de mayo de 2014.

Art. 1 del Convenio

Busca reforzar la cooperación para asegurar y obtener pruebas contra la ciberdelincuencia.

Arts. 3 y 4 del Convenio

Establecen cooperación mutua, motivos de negativa y respeto de los derechos humanos.

Art. 8 del Convenio

Prevé autoridades centrales y puntos de contacto disponibles de forma continuada.

Fuentes: U4 · U5. Enlaces completos en el anexo.

De un registro extranjero a una prueba utilizable

Ejemplo hipotético: una empresa uruguaya necesita registros de acceso conservados por un proveedor en otro Estado. Se presupone un instrumento de cooperación aplicable entre ambos Estados.

1

Identificar y preservar - art. 6 del Convenio

Precisar cuenta, fechas y datos necesarios; solicitar su preservación para evitar el borrado. Preservar no equivale a recibir el contenido.

2

Justificar y canalizar - arts. 8 y 9

La solicitud debe describir hechos, autoridad, eventual calificación y diligencia requerida. Las autoridades centrales canalizan las actuaciones.

3

Obtener por la vía legal - art. 7

La autoridad requerida evalúa requisitos y realiza las diligencias que correspondan. Pueden operar motivos de negativa del art. 3 y garantías del art. 4.

4

Documentar y valorar

Registrar recepción, integridad, accesos y cadena de custodia. Contrastar los registros con otros elementos antes de atribuir el hecho a una persona.

Ni una captura ni una IP aislada sustituyen la obtención lícita y la valoración conjunta de la evidencia.

Fuentes: U4 · U5. Enlaces completos en el anexo.

Cibercrimen, ciberseguridad y ciberdefensa

Son ámbitos conectados con objetivos y competencias diferentes.

Investigación del cibercrimen

Busca esclarecer delitos, reunir prueba y atribuir responsabilidades con garantías.

Ciberseguridad

Busca prevenir incidentes, proteger sistemas, responder y recuperar su funcionamiento.

Ciberdefensa

Se vincula con la protección de capacidades e intereses del Estado en el ámbito de la defensa.

Un delito internacional no se convierte por ese solo hecho en una cuestión militar.

Fuentes: U8 · U11. Enlaces completos en el anexo.

Defensa: del decreto a las directivas concretas

El art. 1 de cada decreto aprueba una política desarrollada en su anexo. Los numerales del anexo no son nuevos artículos del decreto.

Decreto 129/016: Política Militar de Defensa

Su anexo desarrolla prevención y mitigación de amenazas, planificación por capacidades y cooperación regional. El Estado Mayor de la Defensa participa en la planificación militar conjunta.

Decreto 371/020: referencia 2020-2025

Su anexo, apartado IX.A.4, identifica ciberataques que afectan disponibilidad, integridad o confidencialidad de información, con posibles consecuencias lógicas y físicas. Directivas XI.A.1 y XI.A.4: preservar soberanía e integridad, incluido el ciberespacio, y coordinar valoración de riesgos mediante CODENA/CIDEN. XI.A.9: planificación de capacidades y coordinación del Ministerio de Defensa y ESMADE.

Decreto Reservado 44/018

Vinculado con un plan nacional de protección de activos e infraestructuras críticas frente a amenazas terroristas.

Su carácter reservado limita el acceso a su contenido. Las fuentes oficiales públicas permiten identificar su finalidad, pero no detallar todas sus medidas.

Estas políticas deben leerse en su contexto temporal y dentro de las competencias legales; no son una autorización general para intervenir sistemas.

Fuentes: U6 · U7 · D1 · D2 · U8 · U9. Enlaces completos en el anexo.

Servicios esenciales: un ataque puede tener efectos físicos 🟡

Escenario hipotético: un ataque deja sin acceso a sistemas de una red hospitalaria y afecta la coordinación de atención.

Disponibilidad

La información no está accesible cuando se necesita. Ejemplo: no poder consultar una historia clínica.

Integridad

Los datos son alterados. Ejemplo: cambios no autorizados en información que se utiliza para decidir un tratamiento.

Confidencialidad

Personas no autorizadas acceden a información. Ejemplo: exposición de datos de salud.

Respuesta coordinada: los operadores contienen y recuperan; la investigación penal reúne prueba; la autoridad de datos interviene en su ámbito. La dimensión de defensa debe evaluarse según amenaza y competencias.

Fuentes: U6 · U7 · D1 · D2 · U8 · U9. Enlaces completos en el anexo.

De la Directiva 95/46/CE al GDPR

El Reglamento General de Protección de Datos es el Reglamento (UE) 2016/679, aprobado el 27 de abril de 2016.

Antes: Directiva 95/46/CE

Fue el marco europeo precedente de protección de datos personales.

Art. 94 del GDPR

Deroga la Directiva anterior.

Art. 99 del GDPR

Establece su entrada en vigor y su aplicación desde el 25 de mayo de 2018.

GDPR y RGPD son las siglas en inglés y español del mismo reglamento.

Fuentes: E1. Enlaces completos en el anexo.

Principios: cómo se traducen en decisiones

Art. 5: una organización debe cumplir los principios y poder demostrarlo. Art. 4: responsable decide fines y medios; encargado trata datos por su cuenta.

Licitud, lealtad y transparencia

Explicar de forma comprensible qué se hará con los datos y contar con una justificación válida. Ejemplo: informar quién gestiona un formulario y para qué.

Finalidad y minimización

Usar los datos para propósitos determinados y recoger solo lo necesario. Ejemplo: un envío requiere dirección, pero no cualquier información personal adicional.

Exactitud y conservación limitada

Corregir errores y definir plazos de conservación ligados a la finalidad y las obligaciones aplicables.

Seguridad y responsabilidad demostrable

Proteger frente a accesos, pérdida o alteración y documentar las medidas y decisiones. Ejemplo: controles de acceso y registro de actuaciones.

La privacidad afecta al diseño del servicio desde que se decide qué información pedir.

Fuentes: E1 · E2. Enlaces completos en el anexo.

Art. 6 y art. 7: bases jurídicas y consentimiento válido

La base jurídica debe corresponder a la finalidad concreta del tratamiento. El consentimiento no es la única posibilidad.

Consentimiento y contrato

Consentimiento: elección libre e informada, por ejemplo para un uso opcional. Contrato: tratamiento necesario para ejecutarlo, como usar una dirección para entregar una compra.

Obligación legal e interés público

Obligación legal: una norma aplicable exige el tratamiento. Interés público o poderes públicos: una tarea con fundamento en el Derecho de la UE o de un Estado miembro.

Intereses vitales e interés legítimo

Intereses vitales: proteger intereses esenciales para la vida de una persona. Interés legítimo: exige necesidad y ponderación frente a derechos e intereses de las personas; no basta invocar conveniencia comercial.

Art. 7: consentimiento válido

Debe poder demostrarse y retirarse. No puede sustituirse por silencio o casillas premarcadas. Las categorías especiales de datos requieren analizar además el art. 9.

Los ejemplos ilustran las bases; su utilización depende del tratamiento y de todos los requisitos aplicables.

Fuentes: E1 · E6. Enlaces completos en el anexo.

Información, acceso, rectificación y supresión

Los derechos se comprenden mejor como solicitudes que una persona puede dirigir al responsable.

Arts. 13 y 14: información

¿Quién utiliza mis datos, para qué, con qué base y durante cuánto tiempo? La organización debe informar según cómo obtuvo los datos.

Art. 15: acceso

Quiero saber si tratan mis datos y obtener acceso e información sobre su uso.

Art. 16: rectificación

Mi información es inexacta o incompleta y quiero corregirla.

Art. 17: supresión

Quiero que eliminen datos cuando concurra una causa legal. No es absoluto: puede haber obligaciones de conservación y otras excepciones.

Ejemplo hipotético: una persona puede pedir corregir su dirección; borrar toda la documentación de una compra puede requerir otro análisis.

Fuentes: E1 · E3. Enlaces completos en el anexo.

Limitar, trasladar, oponerse y pedir garantías

Cada derecho tiene condiciones. El responsable debe facilitar su ejercicio y explicar las decisiones.

Art. 18: limitación

Pedir que ciertos usos se suspendan en los supuestos previstos, por ejemplo mientras se verifica una impugnación de exactitud.

Art. 20: portabilidad

Recibir datos facilitados por la persona en formato estructurado y transmitirlos, cuando el tratamiento automatizado se base en consentimiento o contrato.

Arts. 21 y 22

Oponerse a determinados tratamientos; el marketing directo tiene una regla específica de oposición. El art. 22 protege frente a ciertas decisiones exclusivamente automatizadas con efectos significativos, con excepciones y garantías.

Art. 12: respuesta

Como regla, responder dentro de un mes. Puede ampliarse dos meses por complejidad o número de solicitudes, informando y justificando dentro del primer mes.

Ejemplo: pedir trasladar datos no significa que cualquier información interna de una empresa sea portable.

Fuentes: E1 · E3. Enlaces completos en el anexo.

Art. 3: ¿cuándo alcanza el GDPR fuera de la UE?

El ámbito territorial depende de la conexión del tratamiento con la Unión Europea.

Establecimiento en la UE

Puede aplicarse al tratamiento en el contexto de las actividades de un establecimiento en la Unión.

Oferta de bienes o servicios

Puede alcanzar a organizaciones extranjeras que dirigen su oferta a personas que se encuentran en la UE.

Seguimiento del comportamiento

También contempla su seguimiento cuando ese comportamiento tiene lugar en la UE.

La nacionalidad europea de una persona o la mera accesibilidad de una web desde Europa no resuelven, por sí solas, la aplicación.

Fuentes: E1 · E2. Enlaces completos en el anexo.

GDPR: seguridad, brechas y sanciones

El reglamento impone obligaciones antes y después de un incidente.

Arts. 25 y 32

Protección de datos desde el diseño y por defecto; medidas de seguridad adecuadas al riesgo.

Art. 33: notificación a la autoridad

Cuando corresponda, sin dilación indebida y, de ser posible, dentro de 72 horas desde que se tiene constancia. Se exceptúan las brechas con riesgo improbable para las personas.

Art. 34: comunicación a las personas

Cuando sea probable un alto riesgo, sin dilación indebida y con las excepciones previstas.

Art. 83: multas

La categoría superior puede alcanzar 20 millones de euros o el 4 % del volumen de negocio anual mundial del ejercicio anterior, la cifra mayor.

No toda brecha exige las mismas comunicaciones ni produce automáticamente la multa máxima.

Fuentes: E1 · E4 · E5. Enlaces completos en el anexo.

Ley 18.331: obligaciones cotidianas ·

Una organización debe justificar y organizar el tratamiento de los datos de clientes, trabajadores y otras personas comprendidas en su actividad.

Art. 9: consentimiento y excepciones

Determinar si necesita consentimiento o si concurre una excepción legal. No asumir que tener un dato autoriza cualquier uso.

Art. 13: información

Informar finalidad, destinatarios, responsable, carácter obligatorio o facultativo de los datos y derechos, entre otros extremos legales.

Arts. 10 y 12: seguridad y responsabilidad

Adoptar medidas técnicas y organizativas apropiadas, con responsabilidad proactiva. Ejemplo: definir permisos y revisar quién accede a datos de clientes.

Arts. 14 y 15: derechos

Atender acceso y solicitudes de rectificación, actualización, inclusión o supresión según los supuestos y límites legales.

Ejemplo: recolectar datos para prestar un servicio exige explicar su uso y protegerlos durante su conservación.

Fuentes: U9 · U13. Enlaces completos en el anexo.

Ley 18.331: transferencias e incidentes

La URCDP es la Unidad Reguladora y de Control de Datos Personales. La protección incluye el destino de los datos y la respuesta a vulneraciones.

Art. 23: transferencias

Analizar el nivel de protección del destino y los mecanismos o excepciones legales. Un proveedor extranjero exige revisar el flujo y sus garantías.

Decreto 64/020, art. 4

El responsable comunica a la URCDP las vulneraciones de seguridad que incidan en la protección de datos en un máximo de 72 horas desde que las conoce.

Contenido práctico

Identificar qué ocurrió, cuándo se conoció, datos y personas afectadas, consecuencias y medidas adoptadas. Documentar el proceso.

Si también aplica el GDPR

Su art. 33 distingue según riesgo y su art. 34 según alto riesgo para las personas. Los requisitos de un régimen no deben trasladarse automáticamente al otro.

La denuncia penal, la comunicación a la autoridad de datos y la recuperación técnica cumplen funciones distintas.

Fuentes: U9 · U10. Enlaces completos en el anexo.

Europa: un reglamento común y desarrollos propios

La comparación utiliza tres preguntas: ámbito, derechos y obligaciones. Las normas no son intercambiables.

Unión Europea: GDPR

Ámbito: art. 3. Derechos: arts. 15 a 22. Seguridad y brechas: arts. 32 a 34. Las autoridades de protección de datos supervisan su cumplimiento.

España: GDPR y LOPDGDD

La Ley Orgánica 3/2018 complementa el GDPR. Art. 5: confidencialidad; art. 7: consentimiento de menores en los términos legales; art. 88: desconexión digital laboral. Autoridad nacional: AEPD, junto con las autoridades autonómicas competentes.

Reino Unido: UK GDPR y DPA 2018

Conserva un régimen propio con principios, derechos y reglas sobre brechas, modificado por la Data (Use and Access) Act 2025. No debe presentarse como idéntico al GDPR de la UE.

Ejemplo de comparación

Ante una filtración, primero se identifica el régimen territorial aplicable; después se examinan la autoridad competente y los requisitos de comunicación.

El uso de nombres parecidos no elimina las diferencias entre el marco de la UE y el británico.

Fuentes: C1 · C3 · E1. Enlaces completos en el anexo.

Canadá y Estados Unidos: ámbitos diferentes

El mismo incidente puede quedar sujeto a normas diferentes según el tipo de organización, actividad y personas afectadas.

Canadá: ámbito y derechos

PIPEDA, secciones 4 y 5: ámbito y obligaciones para las actividades comprendidas. Anexo 1: consentimiento (4.3), salvaguardas (4.7) y acceso (4.9). Importan también las leyes provinciales.

Canadá: incidentes y supervisión

Sección 10.1: reporte y notificación cuando la brecha genera un riesgo real de daño significativo. Interviene el Comisionado de Privacidad federal en el ámbito de PIPEDA.

Estados Unidos: Privacy Act of 1974

5 U.S.C. § 552a regula determinados sistemas de registros de agencias federales: divulgación (b), acceso y rectificación (d), obligaciones de las agencias (e).

Límite de la comparación

La Privacy Act no es una ley general de todas las empresas privadas. Para una tienda o plataforma comercial se necesita identificar la normativa sectorial y estatal que corresponda.

Antes de comparar derechos o plazos, comprobar si la organización está comprendida por la norma.

Fuentes: C2 · C4. Enlaces completos en el anexo.

Respuesta al caso inicial ·

Atacante extranjero, empresa uruguaya y datos vinculados a la UE: un mismo incidente activa preguntas en varios ámbitos.

Investigar

Cibercrimen y Fiscalía actúan según sus competencias; la prueba extranjera puede requerir cooperación.

Restablecer y proteger

La respuesta técnica busca contener el daño y recuperar los servicios, preservando evidencia.

Cumplir las normas de datos

Se analiza la Ley 18.331 y, si existe la conexión territorial correspondiente, el GDPR.

Evaluar la dimensión de defensa

La intervención de ese ámbito exige analizar la naturaleza de la amenaza y las competencias legales.

La respuesta exige coordinación: persecución penal, cooperación, seguridad, defensa cuando corresponda y derechos de las personas.

Fuentes: U5 · U8 · U9 · U11 · E2. Enlaces completos en el anexo.

Gracias

Web realizada por el equipo

https://ciberobservatorio-grupo4.onrender.com/index.html?v=3#/